



정보보호의 날(매주 두번째 주)

▼ 참고 문서

<https://docs.google.com/spreadsheets/d/1lIZiUxP6OQ3SOB3l2lZbWYQB8PvPmOgt/edit?gid=76587892#gid=76587892>

점검항목

1. 클린데스크 (Clean Desk)

- 근거: 인적보안지침, 개인정보보호법
- 점검 항목
 - 퇴근 시 책상 위 중요 문서/매체 방치 여부
 - 개인·고객정보 출력물의 보관함 잠금 여부
 - 공용 프린터·파쇄기 주변 중요문서 잔류 여부
 - PC 화면 잠금

2. 단말기 보안

- 근거: 단말기 보안지침
- 점검 항목
 - 최신 보안패치 적용 여부
 - 백신 동작 및 실시간 감시 여부
 - 화면보호기 자동 잠금(15분 이내) 설정 여부
 - 불필요한 공유폴더·USB 사용 차단 여부
 - 중요 단말기 악성코드 감염 점검(매일 점검 필요)

3. 악성코드 감염 여부

- 근거: 침해사고 대응지침
- 점검 항목
 - 백신/EDR 탐지 로그 확인 (최근 1개월 기준)
 - 악성코드 차단·치료 이력 점검
 - 이상 행위 발생 시 보고 및 대응 여부

4. 계정/권한 관리

- 근거: 계정관리지침
- 점검 항목
 - 퇴직·전보자 계정 폐기/권한 회수 여부(전출, 퇴직 등이 있는 경우 접근 통제 필요)
 - 장기 미사용 계정(90일 이상) 비활성화 여부
 - 관리자 계정 사용내역 샘플링 확인

5. 개인정보/중요정보 보호

- 근거: 개인정보보호법, SG01 개인정보보호지침, 전자금융감독규정 제13조, 제15조?
- 점검 항목
 - PC·서버 내 중요정보(개인정보, 금융정보) 저장 여부 점검 (샘플링)
 - 저장 시 암호화 적용 여부
 - 외부저장매체 사용 기록 점검(보조기억매체 보유 현황 및 관리실태 점검)

6. 물리적 보안 (샘플링 점검)

- 근거: SG06 물리적보안지침
- 점검 항목
 - 출입통제 로그 샘플 확인 (무단/퇴직자 출입 없는지)
 - 외부인 방문 기록 관리 여부

****외부 인력은**

검토 방법

- 백신(매체제어, 바이러스, 개인정보 보호)
 - PC 보안점검 현황: PC보안 설정 점검(대시보드>시스템보안>PC보안점검 현황)
 - PC 보안 내역: 바이러스탐지(대시보드>시스템보안>PC보안 내역)
 - 개인(민감)정보 현황: 개인정보 보유량(대시보드>데이터 보안>개인(민감)정보 현황)
 - 정보 유출 방지(매체제어)
 - 매체제어 승인 내역을 통해 해당 매체로 어떤 파일을 제공했는지 확인 필요
- 쿼리파이 로그(서버, db, k8s)
 -
- 클린데스크
 - 마지막 주 불시점검(?)
 - Slack 공지
 - 불시 점검



- ① 책상 위 업무 서류는 방치하지 않고 항상 정리(개인정보, 비밀번호 메모지에 적어 붙여놓지 않기)
- ② 자리를 비울 때는 PC 화면보호기 설정(타인이 PC에 접근할 수 없도록)
- ③ 복합기 사용 시 공용 사무기기에 문서를 놓고 오거나 방치하지 않기
- ④ 사용 완료한 문서는 파쇄기를 통해 파기하기
- ⑤ 퇴근 전 PC 잠금화면으로 설정 혹은 전원 off, 개인서랍은 잠그고 퇴근
- ⑥ PC에 불필요한 무선매체(USB) 연결 사용금지

- 출입기록 확인: 전산실, 사무실
- CCTV 정상 저장 여부 확인: 전산실, 사무실

필요한 것

1. PC보안 점검 조치는 강제화가 되지 않기 때문에 매달 자동 전사 공지가 필요(점검 후 조치)
2. 매체제어 적용 필요 ⇒ 적용 예정
3. 첫번째 달 월간 보고 후 조치 예정 내역으로 개인정보 보유 여부 검사 시 사업자등록번호는 제외하는 것이 좋을 것으로 판단(개인정보로 판단하지 않고, 너무 많은 양이 검출되고 있음)

보고서 내용

근거 간략하게 상단에 한줄

1. 점검 개요
 - a. 점검대상
 - b. 점검 대상 기간
 - c. 점검일자
 - d. 점검 방식
2. 점검 결과(요약)
 - 표 형태
3. 주요 개선사항
4. 종합 평가

[첨부] 세부 점검 내역

 세부 점검 내역

▼ 근거

<https://intothesec.com/111>

개인정보보호법 제29조(안전조치의무)

개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

동법 시행령 제30조(개인정보의 안전성 확보 조치)

- ① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 해야 한다
- ③ 제1항에 따른 안전성 확보 조치에 관한 세부 기준은 보호위원회가 정하여 고시한다.

개인정보의 안전성 확보조치 기준제10조(물리적 안전조치)

- ② 개인정보처리자는 개인정보가 포함된 서류, 보조저장매체 등을 잠금장치가 있는 안전한 장소에 보관하여야 한다.

제12조(출력·복사시 안전조치)

- ② 개인정보처리자는 개인정보가 포함된 종이 인쇄물, 개인정보가 복사된 외부 저장매체 등 개인정보의 출력·복사물을 안전하게 관리하기 위해 필요한 안전조치를 하여야 한다.

ISMS 인증기준 2.4.7 업무환경 보안

공용으로 사용하는 사무용 기기(문서고, 공용 PC, 복합기, 파일서버 등) 및 개인 업무환경(업무용 PC, 책상 등)을 통하여 개인정보 및 중요정보가 비인가자에게 노출 또는 유출되지 않도록 클린데스크, 정기점검 등 업무환경 보호대책을 수립·이행하여야 한다.

